

Technical Documentation

Architecture, API & Deployment Reference

Version 1.0

Last updated: 2026-04-18

Confidential — Internal Use Only

1. Overview

SecureProfit Hub adalah aplikasi full-stack web untuk firma konsultan IT Security. Stack utama: React + Vite + TypeScript di frontend, Node.js + Express + Prisma di backend, PostgreSQL sebagai database, dan JWT untuk autentikasi.

1.1 Stack Teknologi

Layer	Teknologi
Frontend	React 18, Vite, TypeScript, TailwindCSS, shadcn/ui, Recharts, Wouter, TanStack Query
API Client	Orval-generated React Query hooks (lib/api-client-react)
Backend	Node.js 20+, Express 5, Prisma ORM, Pino logger, Multer (uploads)
Database	PostgreSQL 14+
Auth	JWT (Bearer token, localStorage), bcrypt password hashing
Build	pnpm workspace monorepo

2. Struktur Repository

```
/
% % artifacts/
%   % % api-server/           Express + Prisma backend
%   %   % % src/
%   %   %   % % routes/      (auth, users, clients, projects, resources,
%   %   %   %   %           timesheets, documents, dashboard, uploads)
%   %   %   % % middlewares/auth.ts
%   %   %   % % lib/serializers.ts
%   %   %   % % app.ts
%   %   % % uploads/         File storage (BAST/Invoice PDFs)
%   % % web/                 React + Vite frontend
%   %   % % src/
%   %       % % pages/       (dashboard, projects, timesheets, approvals,
%   %       %   %           clients, users, settings, login)
%   %       % % components/(layout, common, ui [shadcn])
%   %       % % lib/         (auth, format, roles, utils)
%   % % mockup-sandbox/      Component preview (dev only)
% % lib/
%   % % db/                 Prisma schema, client, seed
%   % % api-spec/           openapi.yaml + orval codegen config
%   % % api-client-react/    Generated TanStack Query hooks
%   % % api-zod/             Generated Zod validators
% % scripts/
```

3. Data Model (Prisma)

Skema utama (Prisma) — file lib/db/prisma/schema.prisma.

Model	Field Penting
User	id, email (unique), name, role (UserRole), passwordHash, dailyRate, isActive
Client	id, name, contactPerson, email, phone, industry
Project	id, code (SPK/PO), name, clientId, salesId, pmId, status (ProjectStatus), startDate, endDate, contractValue, estimatedCost, plannedMandays
ProjectResource	id, projectId, userId, roleInProject, plannedMandays, dailyRate
Timesheet	id, userId, projectId, workDate, hours, description, status (TimesheetStatus), approverId, rejectionReason
Document	id, projectId, type (DocumentType: BAST INVOICE CONTRACT OTHER), fileName, fileUrl, uploadedById
Activity	id, type, message, userId, projectId, createdAt

3.1 Enum

- UserRole: MANAGEMENT | PROJECT_MANAGER | SALES | ADMIN_PROJECT | KONSULTAN | TECHNICAL_WRITER
- ProjectStatus: OBSERVATION | ACTIVE | PAUSE | COMPLETE | CLOSED
- TimesheetStatus: DRAFT | SUBMITTED | APPROVED | REJECTED
- DocumentType: BAST | INVOICE | CONTRACT | OTHER

4. Authentication & Authorization

- POST /api/auth/login !' terima { token, user }; token disimpan di localStorage key 'auth_token'.
- Middleware requireAuth memverifikasi Bearer token (HS256, secret = JWT_SECRET).
- Middleware requireRole(...roles) menjaga endpoint sensitif berdasarkan UserRole.
- Password di-hash dengan bcrypt (10 rounds) di seed dan di endpoint /users.

```
// Contoh: requireRole pada endpoint document upload
router.post(
  "/projects/:id/documents",
  requireRole("ADMIN_PROJECT", "MANAGEMENT", "PROJECT_MANAGER"),
  handler,
);
```

5. REST API Reference

Base path: /api. Semua endpoint memerlukan Bearer token kecuali /api/auth/login dan /api/healthz.

5.1 Auth & Users

Method	Path	Role
POST	/auth/login	public

GET	/auth/me	any
POST	/auth/logout	any
GET	/users	MGMT
POST	/users	MGMT
PATCH	/users/:id	MGMT
DELETE	/users/:id	MGMT

5.2 Clients & Projects

Method	Path	Role
GET / POST	/clients	any / MGMT,PM
PATCH / DELETE	/clients/:id	MGMT,PM
GET	/projects?status=	any
POST	/projects	MGMT,PM,SALES
GET	/projects/:id	any
PATCH	/projects/:id (incl. status)	MGMT,PM,SALES
DELETE	/projects/:id	MGMT
GET	/projects/:id/financials	any
GET / POST	/projects/:id/resources	MGMT,PM
DELETE	/resources/:resourceId	MGMT,PM

5.3 Timesheets

Method	Path	Catatan
GET	/timesheets?status&projectId&scope=mine approval all	scope=approval untuk PM
POST	/timesheets	auto-APPROVED untuk PM/MGMT, lainnya SUBMITTED
POST	/timesheets/:id/submit	DRAFT !' SUBMITTED
POST	/timesheets/:id/approve	PM/MGMT only
POST	/timesheets/:id/reject	PM/MGMT, body { reason }
DELETE	/timesheets/:id	owner / PM

Validasi Tanggal Timesheet

workDate harus berada dalam 5 hari kerja terakhir (Senin–Jumat). Validasi dilakukan dengan walking-back skipping Sabtu/Minggu di routes/timesheets.ts.

5.4 Documents & Uploads

Method	Path	Catatan
GET	/projects/:id/documents	list dokumen project
POST	/projects/:id/documents	{type, fileName, fileUrl}; ADMIN_PROJECT/PM/MGMT
DELETE	/documents/:id	ADMIN_PROJECT/PM/MGMT
POST	/uploads	multipart/form-data; field 'file' (PDF, "d10MB") ! {fileName, fileUrl}
GET	/files/:filename	Static serve dari folder uploads/

Auto-Close Logic

Setelah dokumen baru dibuat, jika project.status === 'COMPLETE' DAN project memiliki minimal satu BAST DAN satu INVOICE, status di-update otomatis ke CLOSED dan dicatat di Activity log.

5.5 Dashboard

Method	Path
GET	/dashboard/summary
GET	/dashboard/profit-trend
GET	/dashboard/status-breakdown
GET	/dashboard/top-projects

6. Frontend Architecture

- Routing dengan Wouter; route spesifik (mis. /projects/new) WAJIB didaftarkan sebelum /projects/:id agar match-order benar.
- TanStack Query untuk data fetching, hooks dihasilkan oleh Orval dari openapi.yaml.
- Custom fetcher (lib/api-client-react/src/custom-fetch.ts) menyisipkan Authorization header dari localStorage.
- Dashboard router di pages/dashboard/index.tsx mengarahkan tampilan berdasarkan UserRole: SALES !' SalesDashboard, ADMIN_PROJECT !' AdminProjectDashboard, KONSULTAN/TW !' ConsultantDashboard, lainnya !' ManagementDashboard.
- Tema dark cyber-security: navy background (#0B1220) + accent cyber green; lihat tailwind.config.ts dan src/index.css untuk variabel HSL.

7. Code Generation Workflow (Orval)

- Sumber kebenaran kontrak API: lib/api-spec/openapi.yaml.
- Setiap perubahan endpoint baru di backend HARUS diikuti update spec + regen client.
- Output: lib/api-client-react/src/generated/api.ts (hooks React Query) dan lib/api-zod/src/generated/* (schema Zod).

```
pnpm --filter @workspace/api-spec run codegen
```

8. Setup & Menjalankan Aplikasi

8.1 Prasyarat

- Node.js 20+ dan pnpm 10.
- PostgreSQL 14+ (DATABASE_URL).
- Environment: SESSION_SECRET, JWT_SECRET (di-set otomatis di Replit).

8.2 Instalasi & Migrasi

```
pnpm install
pnpm --filter @workspace/db prisma:generate
pnpm --filter @workspace/db prisma:migrate
pnpm --filter @workspace/db seed
```

8.3 Menjalankan Dev Server

```
# Backend (port 8080, path /api)
pnpm --filter @workspace/api-server run dev

# Frontend (port 22333, path /)
pnpm --filter @workspace/web run dev
```

8.4 Build Production

```
pnpm --filter @workspace/api-server run build
pnpm --filter @workspace/web run build
node artifacts/api-server/dist/index.mjs
```

9. Deployment

- Di Replit: tekan tombol Publish — konfigurasi sudah ada di .replit dan artifact.toml.
- Routing path-based: /api !' api-server (port 8080), / !' static web build.
- Frontend di-build sebagai static, di-serve via fallback rewrite ke /index.html.
- Pastikan env DATABASE_URL & JWT_SECRET ter-set di environment production.

10. Security Notes

- Password disimpan sebagai bcrypt hash; tidak pernah di-return ke klien.
- JWT secret WAJIB diganti per environment via env JWT_SECRET.
- File upload dibatasi MIME type 'application/pdf' dan max size 10 MB.
- RBAC ditegakkan di middleware backend; UI hanya menyembunyikan opsi.
- Rekomendasi: pasang reverse proxy + HTTPS termination (otomatis di Replit).

11. Default Seed Accounts

Email	Role	Password
management@secureprofit.id	MANAGEMENT	password123
pm@secureprofit.id	PROJECT_MANAGER	password123
sales@secureprofit.id	SALES	password123
admin@secureprofit.id	ADMIN_PROJECT	password123
konsultan@secureprofit.id	KONSULTAN	password123
tw@secureprofit.id	TECHNICAL_WRITER	password123

Reminder

Ganti seluruh password default segera setelah deploy ke production.

